

100 Days of Azure DevOps

Day 65 Handout — Three doors: AzureKeyVault@2, linked variable groups, App Service Key Vault references — pick on purpose

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — three ways a secret moves (pipeline is not the app)

Door	Who fetches	What the pipeline log should show
AzureKeyVault@2	The job, via service connection with Secrets User on the vault	*** and a length you print. Never the letters
Variable group linked to KV	Library group authorized to the pipeline; ADO maps secret names to \$(DemoSecret)	Same masking. Do not screenshot the Library value blade
Key Vault reference	App Service / Function app settings: @Microsoft.KeyVault(SecretUri=...)	Pipeline need not see it. The app identity needs Secrets User
Pipeline variable (plain)	You pasted the secret into ADO	A screenshot away from an incident. Not a door — a mailbox
ARM/Bicep getSecret	Deployment identity at deploy time	Fine for resource wiring; still not a YAML literal

Architecture B — pick the door that matches the consumer

Consumer	Default door	Do not
A script step needs the value	AzureKeyVault@2 SecretsFilter: DemoSecret, then env: VAL: \$(DemoSecret)	echo \$(DemoSecret) or system.debug=true on that job
Several jobs, same vault	Linked variable group + 'Authorize' the pipeline	Copy secret into a second non-linked group 'so it is easier'
App runtime only	Key Vault reference on the web app + app managed identity	Download into the pipeline just to re-upload as an app setting
Identity	lab-sc (Day 63) with Key Vault Secrets User on the vault	ACR admin-style passwords in Library

Architecture C — pitfalls that unmask a secret and still look green

Pitfall	What you see	Fix
echo the value	Green job, secret in logs	Print \${#VAL} only. Lab fails if letters appear
system.debug true	Masked variables expand in debug	Keep debug off on secret jobs
Concatenation tricks	ADO masking misses a sliced string	Do not get clever. Length is the proof
Task vs group mash-up	Two copies, different versions of DemoSecret	One door for the lab; document which
Connection lacks data-plane role	AzureKeyVault@2 403	Secrets User on the vault for the SP, not only Contributor on the RG

One-liner to remember

Pipelines that need secrets should fetch them — not store them in variable screenshots. Print the length. If the letters appear, the lab is red even when the job is green.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal azure-100-labs. lab-sc from Day 63. Vault from Day 64. Dummy DemoSecret only.

- 1 Grant the service connection's SP Key Vault Secrets User on the vault (data plane). Confirm lab-sc is the Azure RM connection, not the client ID pasted into YAML.
- 2 Pipelines → Library → Variable group kv-lab. Link secrets from the Key Vault (DemoSecret). Authorize this pipeline. That is door 2 — you may use it instead of (or in addition to) the task, but pick one as the proof.
- 3 Add AzureKeyVault@2 (door 1) with azureSubscription: lab-sc, KeyVaultName, SecretsFilter: DemoSecret, RunAsPreJob: true.
- 4 Next step: bash that prints only \${#VAL} with env VAL: \$(DemoSecret). Read the log. If DemoSecret's letters appear, you failed — fix masking before sleep.
- 5 Write one sentence in docs/kv-pipeline-day65.md about Key Vault references (@Microsoft.KeyVault(SecretUri=...)) as door 3 for apps — pipeline may never see that value.
- 6 No Library screenshots of the secret value. Dummy value stays dummy.

Starter YAML — fetch, then print length

```
pool:
  vmImage: ubuntu-latest
steps:
- task: AzureKeyVault@2
  inputs:
    azureSubscription: lab-sc
    KeyVaultName: <uniquekv>
    SecretsFilter: DemoSecret
    RunAsPreJob: true
- bash: |
    echo "DemoSecret length is ${#VAL}"
  displayName: Prove fetch without printing value
  env:
    VAL: $(DemoSecret)
# Door 3 (app, not this job):
# APPLICATIONINSIGHTS_CONNECTION_STRING=@Microsoft.KeyVault(SecretUri=https://<kv>.vault.azure.net/secrets/AppInsightsCs/)
```

Done checklist

- Pipeline fetched DemoSecret at runtime via task and/or linked group
- Log shows length or ***, never the dummy letters as a souvenir
- Can name all three doors: task, linked group, app Key Vault reference
- SP has Secrets User; RG Contributor was not the fix

Tomorrow — Day 66

Azure Policy — deny/audit so Finance is not your bouncer